TWAGIRUMUKIZA
Cybersécurité · GRC · Formation

BTS SIO SISR · THÈME 3 · SÉANCE 1

Risques liés aux usages des utilisateurs

Support de cours — BYOD, télétravail, supports amovibles, ingénierie sociale, phishing et charte informatique

DURÉE	NIVEAU	FOCUS EXAMEN
2 heures	BTS SIO SISR	Phishing

Sommaire

1. Objectifs pédagogiques . . . 3

2. Déroulement de la séance . . . 3

Partie 1 — Pourquoi sécuriser les usages des utilisateurs ? . . . 3

1.1. Le facteur humain en cybersécurité . . . 3

1.2. Les trois objectifs de sécurité . . . 4

Partie 2 — Les risques liés aux usages informatiques . . . 4

2.1. Le BYOD : utiliser son équipement personnel . . . 4

2.2. Le télétravail . . . 6

2.3. Les supports amovibles . . . 7

Partie 3 — L'ingénierie sociale et le phishing . . . 8

3.1. Qu'est-ce que l'ingénierie sociale ? . . . 8

3.2. Définition du phishing . . . 8

3.3. Anatomie d'un courriel de phishing . . . 9

3.4. Comment vérifier un message suspect ? . . . 9

3.5. Que faire si l'on a cliqué sur un lien de phishing ? . . . 10

3.6. Les variantes du phishing . . . 11

Partie 4 — La charte informatique et la politique d'usage acceptable . . . 13

4.1. Qu'est-ce qu'une charte informatique ? . . . 13

4.2. Qu'est-ce qu'une politique d'usage acceptable ? . . . 14

4.3. Comment analyser une charte lors de l'examen ? . . . 15

Partie 5 — Étude de cas type BTS SIO . . . 16

Questions (QCM) . . . 16

Corrigé rédigé — Méthode attendue à l'examen . . . 17

Partie 6 — Synthèse à mémoriser . . . 18

Bilan de la séance . . . 18

1. Objectifs pédagogiques

À la fin de cette séance, vous devez être capable de :

1	Identifier les risques liés aux usages informatiques des utilisateurs.
2	Expliquer les risques du BYOD, du télétravail et des supports amovibles.
3	Reconnaître une tentative de phishing et comprendre les mécanismes de l'ingénierie sociale.
4	Expliquer le rôle d'une charte informatique et d'une politique d'usage acceptable.
5	Proposer des mesures de prévention adaptées à une situation professionnelle.
6	Analyser un document simple et justifier vos recommandations, comme lors d'une épreuve de BTS SIO.

2. Déroulement de la séance

Temps	Activité
0–15 min	Introduction : les usages numériques en entreprise
15–35 min	BYOD, télétravail et supports amovibles
35–70 min	Ingénierie sociale et phishing
70–90 min	Charte informatique et usages acceptables
90–110 min	Étude de cas et analyse documentaire
110–120 min	QCM et synthèse

Partie 1 — Pourquoi sécuriser les usages des utilisateurs ?

1.1. Le facteur humain en cybersécurité

Une organisation possède généralement plusieurs moyens de protection :

- Un pare-feu pour filtrer les communications réseau.
- Un antivirus ou un EDR pour détecter des comportements malveillants sur les postes.
- Une authentification forte pour protéger les comptes.
- Des sauvegardes pour restaurer les données.
- Des règles internes pour encadrer les usages informatiques.

Cependant, ces protections ne suppriment pas tous les risques.

Un utilisateur peut, par exemple, communiquer son mot de passe sur un faux site, ouvrir une pièce jointe malveillante ou envoyer un document confidentiel au mauvais destinataire.

DÉFINITION Le **risque lié aux usages** correspond à la possibilité qu'un comportement, une erreur ou une manipulation d'un utilisateur compromette la confidentialité, l'intégrité ou la disponibilité du système d'information.

EXEMPLE CONCRET

Un salarié reçoit un courriel qui semble provenir du service informatique. Le message lui demande de confirmer son mot de passe pour éviter la désactivation de son compte.

Il clique sur le lien et saisit ses identifiants sur un faux site.

Conséquence possible : un attaquant récupère ses identifiants et tente d'accéder aux ressources de l'entreprise.

1.2. Les trois objectifs de sécurité

Les usages des utilisateurs peuvent menacer les trois objectifs fondamentaux de sécurité, appelés souvent **triade DIC**.

Confidentialité

Seules les personnes autorisées doivent accéder aux informations.

Exemple : un salarié transmet un fichier contenant les données des clients à une personne extérieure.

Intégrité

Les informations ne doivent pas être modifiées de manière non autorisée.

Exemple : un attaquant modifie un RIB dans une facture transmise par courriel.

Disponibilité

Les services et les données doivent rester accessibles aux utilisateurs autorisés.

Exemple : un salarié ouvre une pièce jointe qui déclenche un rançongiciel bloquant l'accès aux fichiers partagés.

À RETENIR POUR L'EXAMEN Face à un incident, cherchez toujours à déterminer quel objectif de sécurité est menacé, quelles sont les conséquences et quelles mesures peuvent réduire le risque.

Partie 2 — Les risques liés aux usages informatiques

2.1. Le BYOD : utiliser son équipement personnel

BYOD signifie *Bring Your Own Device*, c'est-à-dire « apportez votre propre équipement ».

Un salarié utilise son matériel personnel pour accéder aux ressources de son organisation : ordinateur portable, smartphone ou tablette.

EXEMPLE

Une entreprise autorise un commercial à consulter ses courriels professionnels depuis son smartphone personnel.

Ce smartphone peut contenir simultanément :

- Des courriels professionnels.
- Des photographies personnelles.
- Des applications téléchargées hors des circuits habituels.
- Des données d'authentification enregistrées dans le navigateur.

Si le téléphone est perdu ou compromis, les données professionnelles peuvent être exposées.

Les principaux risques du BYOD

Risque	Explication	Conséquence possible
Perte ou vol	L'appareil disparaît.	Accès non autorisé aux données
Système non mis à jour	Des vulnérabilités restent présentes.	Compromission de l'appareil
Applications risquées	Une application collecte des données ou est malveillante.	Fuite d'informations
Absence de contrôle	L'entreprise ne maîtrise pas suffisamment l'appareil.	Difficulté à détecter ou contenir un incident
Usage familial	D'autres personnes utilisent l'appareil.	Accès accidentel aux données professionnelles

Comment sécuriser le BYOD ?

- Définir les appareils autorisés dans une politique écrite.
- Exiger un système d'exploitation à jour et un verrouillage de l'appareil.
- Activer l'authentification multifacteur (MFA).
- Limiter les accès aux seules ressources nécessaires.
- Séparer, lorsque c'est possible, les données professionnelles des données personnelles.
- Prévoir une procédure de signalement en cas de perte ou de vol.
- Utiliser une solution de gestion des appareils mobiles, telle qu'un MDM, si elle est adaptée à l'organisation.

POINT IMPORTANT Utiliser son téléphone personnel ne signifie pas automatiquement que le BYOD est interdit ou dangereux. Le risque dépend notamment des accès accordés, de la sécurité de l'appareil et des règles mises en place.

2.2. Le télétravail

Le télétravail permet à un salarié d'effectuer ses activités hors des locaux de l'entreprise, notamment depuis son domicile.

Il peut nécessiter l'accès à distance aux applications internes, aux fichiers partagés ou aux outils collaboratifs.

Les risques du télétravail

1. **Réseau Wi-Fi mal sécurisé**
   Un réseau domestique mal configuré peut faciliter certaines attaques contre les appareils connectés.
2. **Utilisation d'un ordinateur personnel**
   L'appareil peut être obsolète, partagé ou insuffisamment protégé.
3. **Connexion sur un Wi-Fi public**
   Un réseau public non fiable peut exposer l'utilisateur à des points d'accès frauduleux ou à des interceptions de communications mal protégées.
4. **Vol ou perte de matériel**
   Un ordinateur professionnel laissé sans surveillance peut donner accès à des informations confidentielles.
5. **Confusion entre environnement professionnel et personnel**
   Des documents professionnels peuvent être copiés vers une messagerie personnelle ou un service de stockage non autorisé.

Les mesures de prévention

- Utiliser de préférence un ordinateur administré par l'entreprise.
- Maintenir les logiciels et le système d'exploitation à jour.
- Utiliser les accès distants approuvés par l'organisation, avec une authentification forte.
- Recourir au VPN lorsqu'il est prévu par la politique de sécurité.
- Verrouiller sa session dès que l'on s'éloigne de son poste.
- Éviter de transférer des fichiers professionnels vers des services personnels non autorisés.
- Respecter les consignes relatives aux données confidentielles.

À quoi sert un VPN ?

Un **VPN** (*Virtual Private Network*) crée un tunnel de communication protégé entre un appareil et un réseau ou service distant.

Il peut contribuer à protéger les échanges sur un réseau non fiable. Cependant, un VPN ne protège pas contre tous les risques : il n'empêche pas, à lui seul, le phishing, le vol de mot de passe ou l'installation d'un logiciel malveillant.

2.3. Les supports amovibles

Un **support amovible** est un équipement de stockage que l'on peut connecter ou retirer facilement.

Exemples

- Clé USB.
- Disque dur externe.
- Carte mémoire.
- Certains smartphones utilisés pour transférer des fichiers.

Quels sont les risques ?

- **Infection :** une clé contient un fichier malveillant.
- **Fuite de données :** un salarié copie des documents confidentiels sur un support personnel.
- **Perte ou vol :** le support disparaît sans protection suffisante.
- **Altération :** les fichiers sont modifiés ou supprimés.
- **Introduction de données non vérifiées :** un fichier récupéré à l'extérieur est utilisé sans contrôle.

Les bonnes pratiques

- Utiliser uniquement les supports autorisés.
- Ne pas connecter une clé USB inconnue.
- Analyser les supports avec les outils de sécurité prévus.
- Chiffrer les supports qui contiennent des données sensibles, selon la politique de l'entreprise.
- Limiter les copies de données au strict nécessaire.
- Signaler immédiatement la perte d'un support professionnel.

> **SITUATION D'EXAMEN** Un salarié trouve une clé USB dans le hall de son entreprise et la branche sur son poste pour identifier son propriétaire.
>
> Le problème est qu'il introduit un support dont l'origine et le contenu ne sont pas vérifiés. Il devrait le remettre au service compétent sans le connecter à son poste.

Partie 3 — L’ingénierie sociale et le phishing

PARTIE ESSENTIELLE Cette partie est essentielle : elle porte sur des situations fréquemment utilisées dans les exercices de cybersécurité.

3.1. Qu’est-ce que l’ingénierie sociale ?

L’**ingénierie sociale** consiste à manipuler une personne afin qu’elle réalise une action favorable à l’attaquant.

L’attaquant ne cherche pas nécessairement à exploiter une faille technique. Il peut chercher à exploiter la confiance, la peur, la curiosité ou le sentiment d’urgence.

Les principales techniques

Prétexting — faux prétexte
L’attaquant invente une situation crédible pour obtenir une information ou une action.
Exemple : il se fait passer pour un technicien informatique.

Phishing — hameçonnage
L’attaquant envoie un message trompeur pour inciter la victime à cliquer, communiquer des identifiants ou effectuer un paiement.

Tailgating — intrusion par suivisme
Une personne non autorisée profite de l’ouverture d’une porte par un employé pour entrer dans une zone sécurisée.

Fraude au président
Un fraudeur se fait passer pour un dirigeant ou un interlocuteur de confiance afin d’obtenir un virement ou une opération urgente.

3.2. Définition du phishing

DÉFINITION Le **phishing**, ou **hameçonnage**, est une technique de fraude dans laquelle un attaquant se fait passer pour un organisme ou une personne de confiance afin de tromper sa victime.

L’objectif peut être de :

- Voler des identifiants ou des mots de passe.
- Obtenir des coordonnées bancaires.
- Faire ouvrir une pièce jointe malveillante.
- Faire installer un logiciel malveillant.
- Déclencher un paiement frauduleux.
- Accéder au système d’information de l’organisation.

Le phishing peut arriver par courriel, SMS, téléphone ou messagerie instantanée. Le phishing par SMS est également appelé **smishing**.

3.3. Anatomie d’un courriel de phishing

Exemple fictif de courriel frauduleux

SIMULATION PÉDAGOGIQUE — NE PAS UTILISER COMME VRAI MESSAGE

De : support-securite@entreprise-verification.example

Objet : **URGENT — Votre compte sera bloqué dans 30 minutes**

Bonjour,

Une activité inhabituelle a été détectée sur votre compte professionnel.

Pour éviter sa désactivation, veuillez confirmer immédiatement votre mot de passe en cliquant sur le lien ci-dessous.

Confirmer mon compte

Sans réponse immédiate, votre accès sera définitivement suspendu.

Le support informatique

Comment reconnaître les indices suspects ?

Indice	Pourquoi est-ce suspect ?
Urgence excessive	Le message pousse à agir sans réfléchir.
Menace de blocage	La peur peut conduire à une erreur.
Demande de mot de passe	Un service légitime ne devrait pas demander de communiquer son mot de passe par courriel.
Adresse d’expéditeur inhabituelle	Le domaine peut ne pas correspondre à l’organisation annoncée.
Lien non vérifié	Le lien peut conduire vers un faux site.
Formulation inhabituelle	Les erreurs ou expressions étranges peuvent être des indices.

ATTENTION Un message de phishing peut être parfaitement rédigé et provenir d’un compte légitime compromis. Aucun indice isolé ne permet toujours de conclure avec certitude.

3.4. Comment vérifier un message suspect ?

1. **Examiner l’expéditeur.**
   Vérifier le domaine réel de l’adresse, pas seulement le nom affiché.
2. **Analyser le contexte.**
   Attendiez-vous ce message ? La demande est-elle cohérente avec votre activité ?

3	**Vérifier le lien sans l'ouvrir.** Examiner l'adresse de destination, selon les outils disponibles. Un nom familier affiché dans le message ne garantit rien.
4	**Se méfier des pièces jointes inattendues.** Ne pas les ouvrir tant que leur légitimité n'est pas vérifiée.
5	**Confirmer par un autre canal.** Contacter l'expéditeur supposé au moyen d'un numéro ou d'une adresse déjà connus.
6	**Signaler le message.** Utiliser la procédure prévue par l'organisation, puis supprimer ou isoler le message selon les consignes.

3.5. Que faire si l'on a cliqué sur un lien de phishing ?

Cliquer sur un lien ne signifie pas nécessairement que le poste est compromis. La réaction dépend de ce qui s'est passé ensuite.

Situation	Réaction attendue
Vous avez seulement ouvert le lien	Fermer la page et signaler l'incident conformément aux consignes internes.
Vous avez saisi votre mot de passe	Prévenir rapidement le support, faire réinitialiser le mot de passe depuis un appareil fiable et révoquer les sessions si nécessaire.
Vous avez validé une notification MFA inattendue	Prévenir immédiatement le service de sécurité.
Vous avez ouvert ou exécuté un fichier	Avertir le support sans attendre et suivre ses instructions. Ne pas tenter de supprimer soi-même les traces ou de réparer le poste sans coordination.
Un paiement a été effectué	Alerter immédiatement le service financier et la banque selon la procédure de l'organisation.

RÉFLEXE PROFESSIONNEL Signaler rapidement un incident, même si l'on pense avoir commis une erreur. Un signalement précoce peut limiter les conséquences.

3.6. Les variantes du phishing

Il existe de nombreuses variantes du phishing (hameçonnage). Les attaques peuvent passer par les courriels, les SMS, les appels téléphoniques ou les réseaux sociaux. Le **quishing**, qui exploite les QR codes, est une notion à connaître.

Les principales variantes du phishing

Variante	Principe	Exemple
1. Phishing (hameçonnage par message)	Un faux message, par courriel, imite une banque, une administration ou un service informatique pour voler des identifiants ou pousser la victime à ouvrir une pièce jointe.	« Votre compte Microsoft sera suspendu. Cliquez ici. »
2. Quishing (phishing par QR code) — à connaître	Le fraudeur utilise un QR code qui redirige vers un faux site ou une page malveillante.	Un faux QR code sur un avis de livraison demande de payer des frais ou de saisir ses coordonnées bancaires.
3. Smishing (phishing par SMS)	L'attaquant envoie un SMS frauduleux qui pousse à cliquer sur un lien ou à fournir des informations.	« Votre colis est bloqué. Réglez 1,99 € pour le recevoir. »
4. Vishing (phishing vocal)	Le fraudeur téléphone en se faisant passer pour un conseiller bancaire, un technicien ou un agent d'une administration.	« Je suis du support informatique. Donnez-moi votre code de connexion pour débloquer votre compte. »
5. Spear phishing (phishing ciblé)	Le message est personnalisé pour une personne ou une organisation précise.	Un salarié reçoit un faux courriel qui reprend le nom de son responsable et un projet réel.
6. Whaling (phishing visant les dirigeants)	Attaque ciblée contre un dirigeant ou une personne disposant d'un niveau élevé de responsabilité.	Un faux message demande au directeur financier de réaliser un virement confidentiel urgent.
7. Angler phishing (réseaux sociaux)	Le fraudeur se fait passer pour un service client ou une marque sur un réseau social.	Un faux compte d'assistance demande des identifiants par message privé.
8. Clone phishing (phishing par clonage)	Un message légitime est copié puis modifié pour remplacer un lien ou une pièce jointe par un élément malveillant.	Un faux courriel reprend un échange réel avec un lien de partage de document frauduleux.

Autres termes utiles en cybersécurité

Terme	Principe	Exemple
BEC (Business Email Compromise)	Compromission ou usurpation d'une messagerie professionnelle pour frauder.	Faux changement de RIB d'un fournisseur.
Consent phishing	Tromper la victime pour qu'elle autorise une application à accéder à ses données.	Fausse demande d'autorisation d'accès à Microsoft 365.
Pharming	Redirection vers un faux site, parfois à la suite d'une compromission technique.	L'utilisateur arrive sur un faux site bancaire.
Search engine phishing	Utilisation de faux sites ou de publicités frauduleuses dans les résultats de recherche.	Une fausse page de connexion apparaît dans une annonce sponsorisée.

Ces techniques sont apparentées au phishing, mais ne désignent pas toutes exactement le même mécanisme.

POUR APPROFONDIR Cybermalveillance.gouv.fr : *Le quishing, l'hameçonnage par QR code* ; CyberDico de l'ANSSI.

Le mémo à donner aux étudiants

Le canal permet de mémoriser les variantes :

Canal / cible		Variante
Courriel	→	**Phishing**
SMS	→	**Smishing**
Appel téléphonique	→	**Vishing**
QR code	→	**Quishing**
Cible précisément choisie	→	**Spear phishing**
Dirigeant ciblé	→	**Whaling**
Faux support sur les réseaux sociaux	→	**Angler phishing**

ATTENTION Plusieurs variantes peuvent être combinées dans une même attaque.

À apprendre en priorité pour le BTS SIO

Phishing, smishing, vishing, quishing, spear phishing et BEC : pour chacun, retenir un exemple, un risque et une mesure de protection.

Variante	Exemple	Risque	Mesure de protection
Phishing	Faux courriel « compte suspendu ».	Vol d'identifiants.	Vérifier l'expéditeur et le lien, activer le MFA, signaler le message.
Smishing	SMS « colis bloqué, réglez 1,99 € ».	Vol de coordonnées bancaires.	Ne pas cliquer, passer par le site ou l'application officiels, signaler.
Vishing	Faux support informatique qui demande un code de connexion.	Prise de contrôle d'un compte.	Ne jamais communiquer un code, raccrocher et rappeler un numéro officiel.
Quishing	Faux QR code sur un avis de livraison.	Redirection vers un faux site, vol de données ou de paiement.	Ne pas scanner un QR code inattendu, vérifier l'adresse affichée avant d'ouvrir.
Spear phishing	Faux courriel reprenant le nom d'un responsable et un projet réel.	Compromission ciblée d'un salarié ou d'une organisation.	Vérifier la demande par un canal indépendant, sensibiliser les utilisateurs.
BEC	Faux changement de RIB d'un fournisseur.	Virement frauduleux.	Double validation des changements bancaires, confirmation auprès d'un contact connu.

Partie 4 — La charte informatique et la politique d'usage acceptable

4.1. Qu'est-ce qu'une charte informatique ?

Une **charte informatique** est un document qui définit les règles d'utilisation des ressources numériques d'une organisation.

Elle peut concerner :

- Les ordinateurs et smartphones professionnels.
- Les comptes et mots de passe.
- La messagerie et la navigation Internet.
- Les outils collaboratifs et le stockage de fichiers.
- Le télétravail et les supports amovibles.
- Le signalement des incidents.
- Les usages autorisés et interdits.

Elle permet de préciser les comportements attendus des utilisateurs et leurs responsabilités.

4.2. Qu’est-ce qu’une politique d’usage acceptable ?

La **politique d’usage acceptable** décrit les usages permis, limités ou interdits des équipements et services informatiques.

Par exemple :

Usage	Exemple de règle
Messagerie	Ne pas transmettre de données confidentielles à un destinataire non autorisé.
Mots de passe	Ne jamais communiquer son mot de passe à un collègue.
Télétravail	Utiliser les accès distants approuvés par l’entreprise.
Clés USB	N’utiliser que les supports autorisés.
Phishing	Signaler les messages suspects au service compétent.
Logiciels	Ne pas installer de logiciels sans autorisation lorsque celle-ci est requise.
Données	Ne pas copier des documents professionnels vers un espace personnel non autorisé.

Une charte et une politique d’usage peuvent être réunies dans un même document. Leur organisation exacte dépend de l’entreprise.

4.3. Comment analyser une charte lors de l’examen ?

Prenons cet extrait fictif :

DOCUMENT 1 — EXTRAIT DE CHARTE INFORMATIQUE

Entreprise fictive : ABC Services

- Les salariés peuvent utiliser leur smartphone personnel pour consulter leurs courriels professionnels.
- Les utilisateurs doivent protéger leurs identifiants.
- Les clés USB personnelles sont autorisées sans contrôle particulier.
- Les messages suspects doivent être signalés au support informatique.
- Aucun dispositif spécifique n’est prévu pour la connexion à distance.

Analyse des écarts

Règle ou situation	Problème identifié	Recommandation
BYOD autorisé sans conditions précisées	Risque de fuite de données ou d’accès non autorisé	Définir les conditions de sécurité du BYOD.
Clés USB personnelles sans contrôle	Introduction possible de fichiers malveillants et fuite de données	Limiter les supports autorisés et prévoir des contrôles adaptés.
Connexion distante sans dispositif précisé	Accès potentiellement insuffisamment protégé	Définir une procédure d’accès distant sécurisé, avec authentification forte.
Signalement des messages suspects	Bonne pratique déjà présente	Maintenir la règle et sensibiliser les utilisateurs.

ATTENTION L’absence d’une règle dans un extrait ne prouve pas forcément que toute l’entreprise est dépourvue de mesures de sécurité. Il faut rester dans le périmètre du document analysé.

Partie 5 — Étude de cas type BTS SIO

Contexte : l'entreprise NovaCom

NovaCom est une PME de 80 salariés. Plusieurs employés télétravaillent deux jours par semaine. L'entreprise autorise l'utilisation des smartphones personnels pour consulter la messagerie professionnelle.

Un lundi matin, le service informatique reçoit les informations suivantes :

INCIDENT A — PHISHING

Une comptable reçoit un message prétendument envoyé par Microsoft. Le message indique que son compte sera suspendu si elle ne confirme pas son mot de passe.

INCIDENT B — BYOD

Un commercial perd son smartphone personnel sur lequel sa messagerie professionnelle est connectée.

INCIDENT C — SUPPORT AMOVIBLE

Un salarié branche une clé USB trouvée dans une salle de réunion pour récupérer un document qui pourrait intéresser son équipe.

Questions (QCM)

1. Quel est le principal risque de l'incident A ?

- ☐ Une panne matérielle
- ☐ Le vol d'identifiants par phishing
- ☐ Une coupure électrique

2. Quelle mesure est adaptée à l'incident B ?

- ☐ Attendre que le téléphone soit retrouvé
- ☐ Alerter le support et appliquer la procédure de révocation des accès
- ☐ Publier un message sur les réseaux sociaux

3. Que devait faire le salarié face à la clé USB inconnue ?

- ☐ La brancher sur son ordinateur
- ☐ La remettre au service compétent sans la connecter
- ☐ Copier tous les fichiers

4. Quelle mesure réduit le risque lié au BYOD ?

- ☐ Autoriser tous les appareils sans condition
- ☐ Définir des exigences de sécurité et limiter les accès
- ☐ Partager les mots de passe entre collègues

5. Pourquoi une charte informatique est-elle utile ?

- ☐ Elle remplace tous les outils de sécurité
- ☐ Elle définit les règles et comportements attendus
- ☐ Elle empêche toute attaque

Score : _____ / 5 bonnes réponses

Corrigé rédigé — Méthode attendue à l'examen

Pour chaque situation, utilisez la structure suivante :

D'après le document... → **Problème** → **Risque** → **Principe de sécurité** → **Solution** → **Bénéfice**

Exemple de réponse : incident A

RÉPONSE MODÈLE

D'après le document, la comptable reçoit un courriel qui menace de suspendre son compte et lui demande de confirmer son mot de passe. Cette situation présente les caractéristiques d'une tentative de phishing.

Le principal risque est le vol de ses identifiants, qui pourrait permettre à un attaquant d'accéder à la messagerie et aux informations professionnelles. Le principe de sécurité à appliquer est la protection des moyens d'authentification et la vérification de l'origine des demandes.

Il faut éviter de cliquer sur le lien, vérifier la demande par un canal indépendant et signaler le message au support informatique. Cette mesure réduit le risque de compromission du compte et permet à l'entreprise de prendre les mesures de protection nécessaires.

Partie 6 — Synthèse à mémoriser

Notion	Définition essentielle
BYOD	Utilisation d'un appareil personnel pour accéder aux ressources professionnelles.
Télétravail	Activité professionnelle effectuée à distance des locaux de l'entreprise.
Support amovible	Support de stockage facilement connectable et retirable, comme une clé USB.
Ingénierie sociale	Manipulation d'une personne pour obtenir une information ou une action.
Phishing	Tromperie visant notamment à voler des identifiants, des données ou de l'argent.
Charte informatique	Document qui définit les règles d'utilisation des ressources numériques.
VPN	Tunnel de communication protégé pour accéder à un réseau ou service distant.
MFA	Authentification reposant sur plusieurs facteurs distincts.
Confidentialité	Protection des informations contre les accès non autorisés.
Intégrité	Protection contre les modifications non autorisées.
Disponibilité	Accès aux ressources par les personnes autorisées lorsqu'elles en ont besoin.

Les cinq réflexes à retenir

1. Ne jamais communiquer son mot de passe à la suite d'une demande reçue par courriel.
2. Vérifier une demande inhabituelle par un canal indépendant.
3. Ne jamais connecter un support USB dont l'origine est inconnue.
4. Respecter les règles de sécurité du télétravail et du BYOD.
5. Signaler rapidement toute perte, tout message suspect ou tout incident.

Bilan de la séance

L'utilisateur est un acteur essentiel de la cybersécurité. Le BYOD, le télétravail et les supports amovibles apportent de la souplesse, mais créent des risques qui doivent être encadrés. L'ingénierie sociale, notamment le phishing, exploite les comportements humains pour contourner les protections techniques.

La sécurité repose donc sur trois leviers complémentaires : **la sensibilisation des utilisateurs, les mesures techniques et les règles organisationnelles**.

> **PRÉPARATION À LA SÉANCE 2** Sensibilisation et défenses techniques — MFA, antivirus, EDR et bonnes pratiques de protection des postes.